

Auditoría final del backend AshaKids

Corte 2026-10-09-17. API HTTPS y Supabase después del despliegue. Ejecución: 9 de octubre de 2026, 21:15 a 21:33, America/Lima. Evaluación técnica asistida para el equipo AshaKids; no pentest, certificación sanitaria ni nota académica oficial.

Repositorio: <https://github.com/sromansilva/ashakids-platform> . Rama local piero-dev, SHA 7fb36680e0c5856036bcf1de69263366247e9126, V25, árbol funcional limpio al iniciar. API pública <https://ashakids.onrender.com>, imagen V24, SHA 62905fc0480fffd21fb6b2d969592700608d64bb. V25 cambia documentos y preparación SCRAM, sin cambios de app respecto de V24. Un SHA no acredita por sí solo el estado de la BD.

01 Dictamen ejecutivo

Puntaje técnico 91 sobre 100. El núcleo funciona mediante HTTPS y persiste en Supabase con ashakids_runtime, TLS verificado y permisos limitados. Se obtuvieron 144 respuestas finales esperadas: 101 del recorrido, 29 variantes y 14 comprobaciones adicionales. El backend rechaza correctamente los metadatos que envía por error el editor de reportes; el fallo de interfaz se registra en el informe frontend 16.

Criterio / máximo	Corte 14	Actual	Fundamento y límite
Funciones y persistencia / 30	28	28	Núcleo real, concurrencia y lectura posterior; dos DELETE físicos sin ensayo.
Modelo y conexión / 15	15	15	19 modelos sin diferencias; TLS y metadatos actuales.
Seguridad y permisos / 20	16	18	HTTPS, cookie Secure y origen rechazado; rotación anterior y coste SCRAM pendientes.
Operación y publicación / 15	9	12	Render operativo y readiness; falta restauración/caída/carga.
Validaciones y errores / 10	9	9	422/409 y revocación; no todas las variantes de entrada.
Pruebas y mantenimiento / 10	9	9	138 unidades y evidencia real; advertencias y cobertura limitada.
Total / 100	86	91	Valoración técnica por criterios; no porcentaje de endpoints cubiertos.

Son resultados nuevos, no una suma de cortes anteriores. De 54 operaciones OpenAPI en producción, 52 tuvieron respuesta positiva registrada. Las dos operaciones sin ensayo son borrados físicos, excluidos por autorización. El endpoint raíz JSON de desarrollo no forma parte de OpenAPI del hosting SPA; por eso no se reutiliza el denominador histórico 55.

02 Arquitectura y cambios realizados

React -> HTTP/JSON -> FastAPI -> Pydantic/servicios -> SQLAlchemy/asynccpg -> PostgreSQL 17.6 en Supabase. La aplicación mantiene autenticación propia con Argon2id, sesiones opacas hasheadas y autorización por recurso. No se usa Supabase Auth. Docker sirve frontend y API en el mismo origen de Render Free, Virginia, un worker y despliegue manual.

La auditoría no altera esquema, permisos, contraseñas preexistentes ni fuentes de aplicación. Usa la configuración aprobada de ADR0010/0011/0012; no se vuelve a aplicar B02 ni el cambio de hash. ADMIN/PADRE/TERAPEUTA son roles de AshaKids; ashakids_runtime es una identidad técnica de PostgreSQL.

Inspección READ ONLY actual	Resultado	Límite
Modelo físico	26 tablas públicas; 92 restricciones; 71 índices; 34 FK y 26 PK.	Catálogo, no exportación de filas.
Columnas visibles	154 en 22 tablas concedidas al runtime.	No confundir con 178 visibles al propietario en cortes históricos.
Modelos SQLAlchemy	19 tablas, 0 diferencias en columnas/tipos/nullabilidad/longitudes modeladas.	No certifica todos los defaults ni las reglas de negocio.
RLS y permisos	RLS activa en 26 tablas; 58 políticas del runtime; 16 secuencias USAGE.	Verificación nueva; no se reejecutaron denegaciones DDL/DML del corte 14.
Transporte pooler	TLS 1.3, CERT_REQUIRED y check_hostname true.	Tramo cliente-pooler; no se atribuye al tramo interno pooler-BD.
Identidad SQL	Sin superusuario/bypass/CREATEDB/CREATEROLE/replicación/INHERIT; 0 membresías y 0 objetos propios.	CONNECT y USAGE public; sin CREATE en BD/public.

RLS concede acceso al servidor con USING true y WITH CHECK true por operación; no aísla familias dentro de PostgreSQL. FastAPI sigue imponiendo pertenencia/asignación. Las tablas de mensajes y auditoría permiten SELECT/INSERT, sin UPDATE/DELETE; el catálogo tiene lectura. No hay TRUNCATE, TRIGGER, REFERENCES ni MAINTAIN en tablas.

03 APIs de identidad pacientes y tratamientos

Grupo / permisos	Resultado observado	Evidencia
Login/me/logout de roles nuevos	Identidad válida, cierre 200 y me 401. Diez cookies Secure/HttpOnly/Lax.	journey.json; extra.json
Administración de cuentas nuevas	Crear, consultar, editar, suspender/reactivar y cambiar contraseña sintética.	journey.json; followup.json
Revocación	Suspensión y cambio de contraseña invalidan sesiones; reactivar no revive la antigua.	Rechazos 401 y relogin correcto.
Pacientes / asignaciones	Dos pacientes nuevos, dos tratamientos; lectura y edición autorizadas.	HTTP y SQL posterior.
Separación por recurso	Familia y profesional ajenos obtienen 404; funciones administrativas403 para roles no permitidos.	Casos negativos esperados.
Inactivación lógica	Paciente 98 inactivado y reactivado; el registro existe y está activo al terminar.	No DELETE físico; persistencia.json.

La cuenta ADMIN inicial solo se usó mediante ASGI local para iniciar sesión, crear un ADMIN sintético y cerrar sesión. Su contraseña no se envió a Render. Todas las escrituras clínicas posteriores se limitaron a registros nuevos AUDITORIA17_20261010_021551. No se ejecutó TRUNCATE ni limpieza destructiva.

04 APIs de citas sesiones reportes y sistema

Caso	Resultado actual	Persistencia o rechazo
Reserva/sesión concurrentes	201+409 usando sesiones auth distintas.	Una creación por operación, sin duplicados.
Inicio/cierre concurrentes	200+409 para transiciones de sesión 13.	Estado final y asistencia coherentes.
Reporte concurrente	Una fila completa; último escritor prevalece.	No existe control de versiones que rechace sobrescritura válida.
Reporte/PDF/mensajería	Cuatro campos, PDF y dos mensajes API; tercero enviado por UI.	Relogin conserva reporte; SQL encuentra 3 mensajes.
Privacidad del chat	Admin recibe 403 al intentar leer conversación privada.	No se concede acceso por ser administrador clínico.
Origen externo	POST/logout con Origen ajeno403; sesión sigue válida.	No se sustituyó la cookie por un token expuesto.
Sistema	health200, readiness200 y rutas SPA200 con Accept HTML.	Readiness verifica conexión; no certifica recuperación ni todos los datos.

Persistencia final independiente:6 usuarios, 2 pacientes activos, 2 tratamientos, 2 reservas, 2 sesiones FINALIZADA, 1 reporte completo, 3 mensajes y 0 sesiones auth nuevas sin revocar. IDs78..83/97, 98/17, 18/14, 15/13, 14/chat7. Datos retenidos, identificados y excluibles de métricas reales.

05 APIs no operativas y capacidades faltantes

DELETE /padres/hijos/{id_paciente} y DELETE /admin/cuentas/{id_usuario} no se ejecutaron porque borran físicamente; no se clasifican como rotos. DELETE /pacientes/{key} sí se ensayó con paciente nuevo: es inactivación lógica, seguida de reactivación. La matriz completa de 54 operaciones está en operation-matrix.json.

No se certifican progreso educativo de juegos, validación de pronunciación, firma digital, correo real, llamadas, adjuntos ni incidencias persistentes. Son extensiones separadas del núcleo. Pagos queda fuera del alcance docente; no se propone un servicio de cobro.

No se ensayaron carga sostenida, caída de Supabase, recuperación desde backup, alta disponibilidad ni expiración natural tras esperar el TTL productivo. La regresión local sí verifica lógica temporal y configuración, sin sustituir esa aceptación operativa.

06 Seguridad y riesgos priorizados

B17 01 Prioridad media. Recuperación y operación. El servicio gratuito depende de despertar y disponibilidad del proveedor. Acordar un ensayo de backup/restauración y contingencia en entorno independiente antes de uso real. No se prueba recuperación sobre datos clínicos compartidos.

B17 02 Prioridad media. Sesiones y rotación. HTTPS y revocación funcionan, pero no se rotaron cuentas anteriores porque están fuera de autorización. La expiración natural y la invalidación por TTL deben aceptarse en un ensayo dedicado. El limitador en memoria se prueba localmente; no se certifica defensa distribuida o entre reinicios.

B17 03 Riesgo aceptado de infraestructura. El runtime conserva contraseña aleatoria de 64 caracteres y SCRAM4096 compatible con Supavisor2.9.10. El ajuste de 32768 a 4096 fue autorizado y documentado previamente; este corte no inspecciona ni publica hashes. Revisar posibilidad de aumentar coste cuando el pooler lo soporte y se pruebe. La evidencia del ajuste y de atributos antes/después es heredada del corte 15, no una ejecución nueva.

B17 04 Prioridad media. Edición concurrente de reportes. El comportamiento actual conserva una fila completa con último escritor válido. Si el trabajo exige detectar ediciones antiguas, acordar versionado/conflicto explícito antes de cambiar contrato y modelo. No se considera garantizado que dos editores no sobrescriban contenido entre sí.

B17 05 Prioridad baja. Mantenimiento de pruebas. 19 advertencias: una de Starlette/httpx y 18 de cookies por petición. Resolver sin cambiar permisos ni bajar validación. No fueron fallos funcionales.

El error de edición visto en frontend corresponde al envío de id_reporte_sesion, id_sesion y fecha_creacion junto a los campos clínicos. El backend obtiene 422, conserva el reporte previo y acepta 200 con solo cuatro campos. Mantener extra=forbid; no abrir el esquema para compensar el fallo de la UI.

07 Evidencia de validación y límites

Comando o caso	Entorno y resultado	Archivo
pytest --noconftest -q, selección segura	138 aprobadas, 19 avisos en 9.04s; sin BD clínica ni fixtures destructivas.	backend-tests.txt
Recorrido HTTPS nuevo	101 respuestas esperadas, incluidas negativas.	journey.json
Variantes de cohorte nueva	29 respuestas esperadas; cambio de contraseña sintética y revocación.	followup.json
Sistema y contrato de reporte	14 respuestas esperadas; reproducción422 y versión previa preservada.	extra.json
SQL READ ONLY / TLS modelo y persistencia	Inventario exacto, TLS verificado, 19 modelos sin diferencias y cantidades finales.	runtime-readonly.json; extra.json; persistence.json
pip check	No broken requirements found.	commands.md

Los guiones y comandos de esta ejecución se conservan sanitizados con los informes; no incluyen contraseñas ni URI privada. Se distingue el tramo bootstrap ASGI local de los144 casos HTTPS finales. Los errores iniciales del harness fueron sintaxis, serialización de bytes y Accept omitido para SPA; corregidos antes del cómputo final. La selección pytest inicial falló por permisos de carpetas temporales Windows; el rerun aprobado conserva los19 avisos.

Rúbrica recibida	Evidencia de este corte	Límite
Arquitectura/backend	Capas, OpenAPI y recorridos HTTPS.	52/54 positivos no implica cubrir todas las variantes.
Modelo físico y operaciones	Metadatos, modelo ORM, escrituras nuevas y SQL posterior.	Sin datos reales exportados ni borrados físicos.
Seguridad y pruebas	Roles/recursos, revocación, TLS, concurrencia y unidades.	Sin pentest/carga/recuperación certificadas.

08 Cierre y ruta de entrega

El backend del núcleo queda auditado en el hosting gratuito, con riesgos operativos declarados. El siguiente trabajo acordado es corregir frontend/reportes y accesibilidad, verificar los casos y presentar una propuesta UX/UI para validación. No modificar permisos o datos anteriores para resolver el error de interfaz.

Los Word y PDF separados conservan fuente y evidencias en el repositorio. Cierre previsto V26; publicación efectiva en IMPLEMENTATION_PROGRESS.md y Git. Auto Deploy Off mantiene V24; los ensayos diferidos siguen pendientes.